국가인공지능전략위원회 발표자료

한국 보안의 갈라파고스

어디서부터 잘못됐나

ActiveX에서 AI까지 — 한국이 세계와 다른 길을 걸은 25년의 역사

유호현 · (주)옥소폴리틱스 대표

2026년 3월

본 발표는 개인 의견이며 특정 기관의 공식 입장이 아닙니다

오늘의 이야기

25년 전, 한국과 세계는 같은 출발선에 있었다

```
1999년 — 한국은 세계 최초 수준의 전자정부를 만들었다
     초고속 인터넷 보급률 세계 1위, 온라인 뱅킹, 전자민원
     세계가 부러워했다

     그런데 25년이 지난 2026년,
     한국 시민은 은행 웹사이트에 접속하려면 프로그램 5개를 깔아야 한다
     그 프로그램 중 하나로 북한 해커가 악성코드를 퍼뜨렸다
     세계 어느 나라에서도 이런 걸 요구하지 않는다

     어디서부터 잘못된 걸까?
```

- **제1부:** 90년대 — 같은 출발선
- **제2부:** 2000년대 — 갈림길
- **제3부:** 2010년대 — 격차가 벌어지다
- **제4부:** 2020년대 — AI 시대에 ActiveX 유산
- **제5부:** 전환 경로와 FAQ

01

제1부: 같은 출발선

1990년대 — 한국은 세계를 앞서고 있었다

1990년대 한국

IT 강국의 시작

1990년대 후반, 김대중 정부는 **"Cyber Korea 21"**이라는 국가 프로젝트를 시작했다. 전국에 초고속 인터넷을 깔겠다는 것이었다. 결과는 놀라웠다:

지표	한국	미국	일본
초고속 인터넷 보급률 (2001년)	**100명당 14명** (세계 1위)	100명당 4.5명	100명당 1.7명
가정 초고속 인터넷 비율 (2001년)	**57.3%**	11.1%	—
IT 산업의 GNP 성장 기여도 (2000년)	**50.5%** — 한국 경제 성장의 절반이 IT에서 나왔다		

2001년 기준, 한국은 **초고속 인터넷 보급률에서 2위(캐나다, 6.2명)의 2배 이상을 앞서고 있었다.** 세계 어느 나라도 한국을 따라잡지 못했다. 국제 관측자들은 이것을 "브로드밴드의 기적"이라고 불렀다.

> **이때까지 한국은 진짜 세계 최고였다.** 자부심은 당연했다.

그래도 자랑스러웠다

UN 전자정부 순위 세계 1위

ActiveX와 공인인증서에 기반한 시스템이었지만, **한국의 전자정부는 진짜 세계 최고였다:**

연도	UN 전자정부 순위
2003	13위
2004	5위
2008	6위
2010	**1위**
2012	**1위**
2014	**1위**

3회 연속 세계 1위. 이때 한국이 가진 것:

- 세계 최고 초고속 인터넷 속도
- 온라인으로 거의 모든 행정 처리 가능
- 인터넷 뱅킹 보급률 세계 최상위
- 전자민원, 전자세금, 전자조달

세계가 한국의 전자정부를 벤치마킹했다. **자부심은 당연했다.**

> 하지만 이 모든 것이 ActiveX + Internet Explorer라는 하나의 기술 위에 세워져 있었다. 그리고 세계는 이미 다른 방향으로 움직이기 시작하고 있었다.

1990년대 한국

그런데 문제가 하나 있었다

1990년대, **미국 정부는 강력한 암호화(128비트)의 해외 수출을 금지**하고 있었다. 냉전 시대의 유산이었다. 암호화 기술을 무기로 분류해서, 해외에는 40비트 이하의 약한 암호화만 허용했다. SSL 프로토콜 자체는 전 세계에서 쓸 수 있었지만, **한국에 수출되는 브라우저에는 40비트 SSL만 탑재**됐다. 40비트는 1시간이면 뚫렸다. 은행 업무에 쓸 수 없는 수준이었다.

문제: 안전한 인터넷 뱅킹을 하려면 **128비트 암호화**가 필요했다. 40비트는 1시간이면 뚫렸다. 그런데 한국은 미국산 128비트 SSL을 쓸 수가 없었다.

한국의 대응: 우리가 직접 만들자

1998~1999년, 한국정보보호진흥원(KISA — Korea Internet & Security Agency)이 **SEED**라는 128비트 암호화 알고리즘을 자체 개발했다. 미국 것을 못 쓰니 한국 것을 만든 것이다. **이 결정 자체는 합리적이었다.**

그런데 문제가 하나 더 있었다: 넷스케이프도, 인터넷 익스플로러도, 세계 어떤 브라우저도 **SEED를 지원하지 않았다.** 한국만 쓰는 암호화니까. 브라우저가 SEED를 모르는데, 어떻게 인터넷 뱅킹을 할 수 있을까?

1990년대 세계

인터넷 보안에 국제 표준이 생기다

1994년, 넷스케이프(Netscape)라는 회사가 웹 브라우저를 만들었다. 사람들이 처음으로 인터넷에서 물건을 사기 시작했다. 그런데 문제가 있었다 — **카드 번호를 입력하면 누군가 중간에서 훔쳐볼 수 있었다.**

그래서 넷스케이프가 **SSL**이라는 기술을 만들었다. SSL은 인터넷 통신을 암호화하는 기술이다. 쉽게 말하면, **편지를 봉투에 넣어서 보내는 것**이다. 중간에 누가 가로채도 봉투를 열 수 없다. 웹 브라우저 주소창에 자물쇠 모양이 뜨면 SSL(지금은 TLS로 발전)이 작동하고 있다는 뜻이다.

연도	사건	의미
1994	넷스케이프가 SSL 1.0 개발	인터넷 암호화의 시작 (보안 결함으로 비공개)
1995	SSL 2.0 공개	최초의 공개 암호화 통신. 아마존, 이베이가 전자상거래 시작
1999	TLS 1.0 발표	SSL의 후속 표준. 국제 표준으로 채택 (RFC 2246)

핵심: 보안을 브라우저와 서버 사이에서 처리했다. 사용자 PC에 별도 프로그램을 설치할 필요가 없었다. 이것이 이후 25년간 세계 보안의 기본 원칙이 된다.

ActiveX의 탄생

그래서 ActiveX를 썼다

ActiveX란 마이크로소프트가 만든 기술로, **웹사이트가 사용자의 PC에 프로그램을 설치하고 실행할 수 있게 해주는 것**이다. 브라우저(Internet Explorer) 안에서 작은 프로그램이 돌아가는 구조였다.

한국의 논리:

```
브라우저가 SEED 암호화를 지원 안 한다
→ 그러면 ActiveX로 SEED 암호화 프로그램을 사용자 PC에 설치하자
→ 은행 웹사이트에 접속하면 ActiveX가 자동으로 SEED 암호화를 실행
→ 128비트 암호화 완성!
```

이것도 당시에는 합리적인 선택이었다. 미국이 암호화 수출을 막고 있었고, 브라우저가 한국 암호화를 지원하지 않았으니, ActiveX는 현실적인 유일한 방법이었다.

> **그런데 1년 후인 2000년, 미국이 암호화 수출 제한을 풀었다.** 이제 세계 어느 나라든 128비트 SSL을 자유롭게 쓸 수 있게 됐다. SEED를 쓸 이유도, ActiveX를 쓸 이유도 사라진 것이다. **그런데 한국은 이미 ActiveX 위에 전체 인프라를 올려놓은 뒤였다.**
>
> 한국이 인터넷 강국이라서 세계보다 빨리 움직인 것이 역설적으로 갈라파고스의 원인이 됐다. **1년만 늦게 시작했으면 표준 SSL을 쓸 수 있었고, SEED도 ActiveX도 공인인증서도 필요 없었다.**

전자서명법 (1999)

공인인증서의 탄생 — 법으로 기술을 고정하다

1999년 7월, 한국 정부는 **전자서명법**을 제정했다. 이 법은 공인인증서(PKI — Public Key Infrastructure, 공개키 기반 구조를 이용한 전자서명)에 **손으로 쓴 서명과 동일한 법적 효력**을 부여했다. 온라인으로 금융거래, 관공서 업무, 계약을 할 수 있게 된 것이다.

문제는, 이 법이 **특정 기술(PKI 기반 공인인증서, 즉 공개키 암호화 방식의 인증서 파일)을 유일한 방법으로 지정**했다는 것이다. 다른 방식(지문, 얼굴, 일회용 비밀번호 등)은 법적 효력이 없었다.

그리고 공인인증서는 브라우저가 기본 지원하지 않았다. 결과:

```
공인인증서를 쓰려면 → ActiveX 필수
ActiveX는 Internet Explorer에서만 작동
→ 한국의 모든 금융·공공 서비스가 Internet Explorer 전용이 됨
→ 다른 브라우저(Chrome, Firefox, Safari)로는 은행 업무 불가
→ 맥, 리눅스에서도 불가
```

> **1999년의 법 한 줄이, 이후 21년간 한국의 인터넷을 가둬버렸다.** 이 법은 2020년 12월에야 폐지됐다.

전자서명법의 근본 문제

왜 한국만 사용자에게 개인키를 줬나

1999년 전자서명법의 핵심 논리:

```
한국 정부의 사고방식:
  "거래 당사자가 나중에 '내가 안 했다'고 부인하지 못하게 해야 한다"
  → "부인 방지에는 전자서명이 필요하다"
  → "전자서명에는 개인키가 필요하다"
  → "개인키를 사용자에게 줘야 한다"
  → 사용자가 USB/PC에 파일로 보관하고 직접 관리
```

한국 (1999년)

법이 특정 기술(PKI 인증서)을 유일한 전자서명 수단으로 지정
사용자가 개인키를 파일로 보관
분실, 유출, 갱신을 사용자가 책임

글로벌

"거래 부인 방지"는 서버측 로그 + 다중인증으로 해결
은행이 거래 기록을 보관하면 법적 효력 충분
사용자에게 개인키를 줄 이유가 없다

다른 나라는 "내가 안 했다"는 주장에 대해 서버 로그와 인증 기록으로 대응한다. 한국만 "사용자가 직접 전자서명을 했으니 부인할 수 없다"는 구조를 선택했다.

이론 vs 현실

개인키가 더 안전한 건 맞다. 하지만...

SSH에 쓰는 것과 같은 PKI 기술이다. 이론적으로 비밀번호보다 강력하다. 문제는 구현이다.

이론: 개인키의 장점

- 추측 불가능 (2048비트 랜덤)
- 피싱에 강함 (키 자체를 전송 안 함)
- 수학적으로 위조 불가능
- 부인 방지 (서명 사실을 부정 불가)

현실: 한국의 구현

- USB 메모리에 파일로 저장
- 파일 보호는 결국 비밀번호
- 파일 복사하면 누구나 사용 가능
- 개인키 + 비밀번호 = 비밀번호 수준

```
[한국의 선택]  비밀번호가 약하다 → 개인키가 강하다 → 사용자에게 개인키를 파일로 주자
               → 그 파일을 비밀번호로 보호 → 결국 비밀번호 수준으로 회귀

[글로벌의 선택]  비밀번호가 약하다 → 비밀번호 + 다른 요소를 합치자 (MFA)
               → 비밀번호 + OTP, 생체인증, 하드웨어 키
               → 나중에: 비밀번호 자체를 없애자 (FIDO2/패스키)
```

비유: "주차권이 비밀번호보다 안전하니까 국민에게 주차권을 나눠주자" → 주차권을 잃어버리니까 주차권에 비밀번호를 적어둠 → 결국 비밀번호가 뚫리면 주차권도 뚫림. 글로벌은 "번호판 인식으로 주차권 자체를 없애자"를 선택했다.

세대 비교

한국 주차장은 3세대, 한국 은행은 1세대

한국은 번호판 자동 인식 주차 시스템에서 세계를 리드한다. 같은 나라의 인터넷뱅킹은 1999년에 멈춰 있다.

세대	시기	한국 주차장	한국 금융 보안	글로벌 금융 보안
1세대	1990년대	물리 주차권	**공인인증서 (USB)**	비밀번호
2세대	2010년대	앱 주차권/전자 정산	**카카오/PASS 인증서**	비밀번호 + MFA
3세대	2020년대	**번호판 자동 인식**	아직 2세대에 멈춤	**FIDO2/패스키**

한국 금융 보안의 "혁신" (2020년)
공인인증서 → 카카오/PASS 인증서
물리 주차권 → 앱 주차권으로 바꾼 수준
여전히 "인증서"라는 매체를 나눠주는 구조

3세대: 매체가 없다
한국 주차장: 번호판만 있으면 됨
글로벌 금융: 지문/얼굴만 있으면 됨
잃어버릴 것 없음, 관리할 것 없음, 설치할 것 없음

한국은 주차장에서 이미 3세대를 구현했다. 같은 기술 철학을 은행에 적용하면 된다. **새로 발명할 것이 없다.**

핵심 개념

다른 나라에는 사용자 개인키가 없다

전 세계 표준 방식에서 일반 사용자에게 개인키를 발급하지 않는다.

```
[한국 공인인증서 모델]
  서버 개인키 → 서버가 관리 (HTTPS 암호화용)
  사용자 개인키 → 사용자가 관리  ← 한국만 이렇게 한다

[글로벌 표준 모델]
  서버 개인키 → 서버가 관리 (HTTPS 암호화용)
  사용자 인증 → 비밀번호 + MFA (개인키 없음)
```

계층	방식	누가 관리
통신 암호화	TLS (서버 인증서)	서버
본인 확인	ID/비밀번호	서버가 해시 저장
추가 인증	OTP, 생체인증	서버 + 사용자 기기
거래 보호	이상거래탐지(FDS)	서버
부인 방지	서버 로그 + 감사 추적	서버

패스키(FIDO2)는 개인키를 사용하지만, 기기의 보안 칩에 저장되어 사용자가 존재 자체를 모른다. 지문이나 얼굴로 자동 사용. 한국 공인인증서와 같은 "개인키"지만 사용자 경험은 정반대다.

2000년대 한국

보이스피싱이 폭발하다

2000년대 중반부터 한국에서 보이스피싱(전화 사기) 피해가 폭발적으로 증가했다.

1조 965억 원

2023년 연간 피해액 (경찰청 통계)

- 하루 평균 **30억 원**이 사기로 빠져나간다
- 피해자 상당수가 **노년층**
- 생활비·전 재산을 잃는 경우 빈번

정부에 엄청난 압박이 가해졌다. "국민이 매일 수십억 원씩 사기 당하고 있는데, 정부는 뭘 하고 있나?"

그래서 나온 대책:

- 키보드 입력을 해커가 훔쳐보지 못하게 → **키보드 보안 프로그램**
- 악성 프로그램이 은행 화면을 조작 못 하게 → **방화벽 프로그램**
- 사용자가 진짜 본인인지 확인 → **공인인증서**, 보안카드, OTP
- 사기범의 IP를 추적하기 위해 → **IP 수집 프로그램**

출발점은 이해할 수 있다.
문제는 방향이었다.

02

제2부: 갈림길

2000년대 — 세계는 서버로, 한국은 PC로

2000년대 세계

브라우저가 스스로를 지키기 시작하다

2008년, 구글이 **Chrome** 브라우저를 출시했다. Chrome의 핵심 혁신은 **"샌드박스(Sandbox)"**라는 기술이었다.

샌드박스란? 어린이 놀이터의 모래놀이 상자(sandbox)에서 이름을 따왔다. 아이가 모래 상자 안에서는 마음껏 놀 수 있지만, 상자 밖으로 모래를 퍼낼 수는 없다. 마찬가지로, 웹사이트는 브라우저 안에서는 자유롭게 동작하지만, **브라우저 밖 — 즉 내 PC의 파일, 프로그램, 키보드 입력에는 접근할 수 없다.**

ActiveX 방식 (한국)

웹사이트가 PC에 프로그램을 **설치하고 실행**할 수 있다. PC의 모든 것에 접근 가능. 보안의 벽이 없다.

샌드박스 방식 (세계)

웹사이트는 브라우저라는 **상자 안에 갇혀** 있다. PC에 접근 불가. 보안의 벽이 있다.

세계의 방향: "웹사이트가 PC에 프로그램을 설치하는 것 자체가 위험하다. 브라우저 안에 가둬야 한다."
한국의 방향: "보안을 위해 PC에 프로그램을 더 깔아야 한다." — 정반대였다.

2004년

PCI DSS — 카드 보안은 서버에서 하라

2004년 12월, Visa, Mastercard, American Express, Discover, JCB — 세계 5대 카드사가 함께 **PCI DSS**라는 보안 표준을 만들었다.

PCI DSS(Payment Card Industry Data Security Standard)란, 카드 결제를 다루는 모든 회사(은행, 쇼핑몰, 결제 대행사)가 지켜야 하는 **국제 보안 규칙**이다. "카드 번호를 어떻게 저장하고, 어떻게 전송하고, 누가 접근할 수 있는지"를 정한다.

핵심 원칙: 보안은 서버에서 한다. 시민의 PC에 뭘 깔아서 보안을 달성하는 게 아니라, 카드 정보를 다루는 회사의 서버가 안전해야 한다는 것이다.

한국

PCI DSS를 채택하지 않음. 대신 **사용자 PC에 보안 프로그램 설치를 의무화**하는 독자 규정 유지.

세계

PCI DSS가 사실상 글로벌 표준이 됨. **서버 보안에 투자하지 않으면 카드 결제를 처리할 수 없는** 구조.

2005년 — 전환점

한국 최초 인터넷 뱅킹 해킹, 그리고 보안프로그램의 탄생

2005년, 해커가 **외환은행 고객의 인터넷 뱅킹 계좌에서 돈을 빼내는 사건**이 발생했다. 한국 최초의 인터넷 뱅킹 해킹이었다. 해커는 키로거(키보드 입력을 몰래 기록하는 프로그램)를 사용해 비밀번호를 훔쳤다.

충격을 받은 정부가 즉각 대응에 나섰다:

```
2005년 8~9월 정보통신부 + 금융감독원 합동 TF 구성
       약 2개월간 전자금융 보안 체계 전면 분석

2005년 10월   "전자금융거래 보안 종합대책" 발표
               → 보안프로그램 설치 의무화 포함
               → OTP(One-Time Password, 일회용 비밀번호) 도입
               → 금융권 정보보호 전담 조직 설립 의무화

2006년     전자금융거래법 제정 (세계 최초의 전자금융 일반법)
               → 하위 규정: 전자금융감독규정
               → 키보드 보안, 방화벽, IP 추적 등 세부 보안 조치를 규정
```

의사결정 구조:

- **법(전자금융거래법):** 국회가 제정
- **세부 규정(전자금융감독규정):** 금융위원회/금융감독원이 제정
- **집행:** 금융감독원이 은행들에게 이행을 요구

> **당시에는 합리적인 대응이었다.** 실제로 키로거를 통한 해킹이 일어났으니, 키보드 보안 프로그램으로 막겠다는 발상은 이해할 수 있다. 문제는 이 "임시 처방"이 **20년간 고착화**된 것이다. 그리고 곧 보이스피싱이라는 전혀 다른 위협이 등장하면서, 이 프로그램들은 **못 막는 것을 막으려고 설치되는** 존재가 되어버렸다.

보이스피싱의 실제 수법

보이스피싱은 이렇게 작동한다

```
1단계: 전화가 온다
   "검찰입니다. 당신 계좌가 범죄에 연루됐습니다."
   "은행입니다. 대출 금리를 낮춰드릴 수 있습니다."

2단계: 피해자가 속는다
  공포, 욕심, 신뢰 — 사람의 심리를 조작한다

3단계: 피해자가 직접 행동한다
   (a) 직접 돈을 이체하거나
   (b) 원격제어 앱(팀뷰어, AnyDesk)을 직접 설치하거나
   (c) 악성 앱을 직접 설치한다

4단계: 돈이 빠져나간다
```

핵심: 피해자가 속아서 자기 손으로 직접 하는 것이다. 해커가 몰래 PC에 침입해서 돈을 빼가는 게 아니다.

> **비유:** 도둑이 현관문을 두드려서 "택배입니다"라고 속이면, 집주인이 직접 문을 열어준다. 이때 **창문에 아무리 쇠창살를 달아봤자 소용없다.** 그런데 한국 정부의 대책은 "창문에 쇠창살를 의무적으로 달아라"인 것이다.

효과 분석

한국의 보안 프로그램이 실제로 막을 수 있는 것

보이스피싱 공격 방식	키보드 보안	방화벽	공인인증서
피해자가 **직접** 이체 버튼을 누름	✗ 못 막음	✗ 못 막음	✗ 못 막음 (본인이 인증)
피해자가 **직접** 원격제어 앱을 설치	✗ 못 막음	✗ 못 막음	✗ 못 막음
피해자가 **직접** 악성 앱을 설치	✗ 못 막음	✗ 못 막음	✗ 못 막음
해커가 몰래 키보드 입력을 훔침	✓ **이것만**	—	—

진짜 효과 있는 대책은 전부 서버에서 한다

대책	작동 방식	어디서?
이상거래탐지(FDS — Fraud Detection System)	"이 사람이 평소와 다른 패턴으로 큰 돈을 보낸다" → 자동 차단	은행 서버
지연이체	큰 금액 이체 시 30분~1시간 후 실행 → 냉각기간	은행 서버
AI 통화 분석	통화 중 "검찰", "계좌 동결" 키워드 감지 → 경고	통신사 서버

이 중 어느 것도 **사용자 PC에 프로그램을 설치할 필요가 없다.**

면책 구조

보안프로그램의 숨겨진 역할

```
[한국의 실제 논리]

사고가 나면 누구 책임인가?
  → 은행: "우리는 보안 프로그램 설치하라고 했잖아요"
  → 금감원: "은행이 보안 조치를 했으니 면책"
  → 결론: 사용자 책임

보안 프로그램의 진짜 역할:
  ✗ 해킹을 막는 것 (실제로 못 막음)
  ✓ 은행의 면책 근거를 만드는 것
```

```
[EU PSD2의 논리]
(PSD2 = Payment Services Directive 2, EU가 만든 결제서비스 법. 2015년 채택, 2019년 시행)

사고가 나면 누구 책임인가?
  → 금융기관이 충분한 서버 보안 조치를 했는가?
  → 아니라면 → 금융기관 책임

결과:
  → "프로그램 깔라고 했으니 우리 잘못 아냐"가 통하지 않는다
  → 은행이 직접 서버 보안에 투자할 수밖에 없다
```

비유: 집에 도둑이 들었다. 경찰이 와서 "쇠창살 설치했습니까?" → "아니요" → "그럼 본인 책임입니다." 도둑이 현관문으로 들어왔는데도.

법적 구조

보안프로그램의 진짜 역할 — 은행의 면책 도구

전자금융거래법 제9조

제1항: 금융사고가 나면, **원칙적으로 금융기관이 책임**을 진다.

제2항: 단, "이용자의 고의 또는 중대한 과실"이 있으면, 이용자에게 책임을 전가할 수 있다.

여기서 "중대한 과실"이 무엇인지는 은행 약관에 적혀 있다:

```
"금융기관이 제공하는 보안프로그램을
설치하지 않은 경우,
이용자의 중대한 과실로 본다"
```

보안프로그램 안 깔면 → 이용자 과실 → 사고 시 이용자 책임 → 은행 면책

실제로 벌어지는 일

```
보이스피싱 사고 발생

은행: "보안프로그램 설치하셨습니까?"
피해자: "네, 다 설치했습니다"
은행: "업데이트는 하셨습니까?"

→ 보안프로그램의 실제 역할:
  ✗ 보이스피싱을 막는 것 (못 막음)
  ✓ "우리는 조치를 했다"는
  면책 근거를 만드는 것
```

EU PSD2 (Payment Services Directive 2, 2015년 채택)

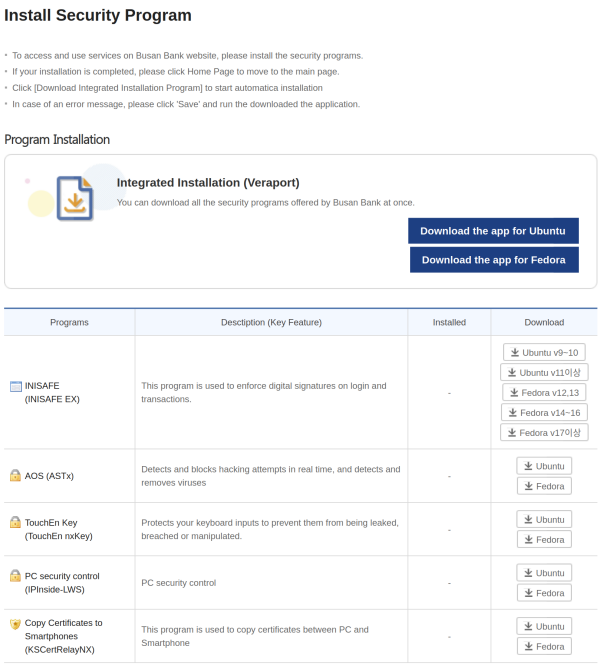
EU(유럽연합)가 만든 결제서비스 법. 사고 시 **금융기관이 서버 보안을 충분히 했는지**를 본다. "프로그램 깔라고 했으니 우리 잘못 아냐"가 통하지 않는다.

2020~2025: 바뀌었나?

2020.12: 공인인증서 "폐지" → "공동인증서"로 이름만 바뀜
2025.02: 전자금융감독규정 293개 규칙 → 166개로 축소. "원칙 중심"으로 전환 방향 제시
하지만: 은행들은 여전히 보안프로그램 설치를 요구하고, 제9조 면책 구조는 그대로

한국 은행의 현실

은행 웹사이트에 접속하면 이런 화면이 뜬다



Install Security Program

- To access and use services on Busan Bank website, please install the security programs.
- If your installation is completed, please click Home Page to move to the main page.
- Click [Download Integrated Installation Program] to start automatica installation
- In case of an error message, please click 'Save' and run the downloaded the application.

Program Installation

Integrated Installation (Veraport)

You can download all the security programs offered by Busan Bank at once.

Download the app for Ubuntu

Download the app for Fedora

Programs	Desctiption (Key Feature)	Installed	Download
INISAFE (INISAFE EX)	This program is used to enforce digital signatures on login and transactions.	-	Ubuntu v9~10 Ubuntu v11이상 Fedora v12,13 Fedora v14~16 Fedora v17이상
AOS (ASTx)	Detects and blocks hacking attempts in real time, and detects and removes viruses	-	Ubuntu Fedora
TouchEn Key (TouchEn nxKey)	Protects your keyboard inputs to prevent them from being leaked, breached or manipulated.	-	Ubuntu Fedora
PC security control (IPInside-LWS)	PC security control	-	Ubuntu Fedora
Copy Certificates to Smartphones (KSCertRelayNX)	This program is used to copy certificates between PC and Smartphone	-	Ubuntu Fedora

부산은행 웹사이트의 보안프로그램 설치 요구 화면 (출처: Palant, 2023)

한국인 PC에는 평균 **9개**의 보안 프로그램이 설치되어 있다 (KAIST 조사).

프로그램	실제로 하는 일
TouchEn nxKey	커널에서 키보드 입력을 가로챔
IPinside	PC의 하드웨어 정보, 설치 목록 수집
AhnLab Safe Transaction	네트워크 트래픽 전체를 감시
Veraport	다른 프로그램을 다운받아 설치
MagicLine4NX	인증서 기반 본인 확인

97.4%가 설치 (거부하면 은행 업무 불가). **59%**는 뭘 하는지 모른다.

03

제3부: 격차가 벌어지다

2010년대 — 세계는 다음 세대로, 한국은 2005년에 멈춰

2012년

FIDO — 비밀번호 없는 세상의 시작

2012년 7월, PayPal, Lenovo 등이 모여 **FIDO Alliance**를 설립했다. 목표: **비밀번호를 없애자.**

FIDO(Fast Identity Online)란, 비밀번호 대신 **지문, 얼굴, 보안 키** 같은 것으로 본인을 확인하는 국제 표준이다. 아이폰의 Face ID, 갤럭시의 지문인식이 FIDO 기반이다.

한국의 공인인증서 (1999년 설계)

USB에 파일을 저장 → 비밀번호(영문 대소문자+숫자+특수문자) 입력 → ActiveX 필요 → 1년마다 갱신

피싱에 취약 (가짜 사이트에서도 동일하게 작동)

FIDO2 (2018년 표준화)

스마트폰에 지문 터치 또는 얼굴 인식 → 끝
설치할 프로그램: 0개

피싱에 원천 면역 — FIDO2 인증은 "이 사이트의 주소가 진짜 은행 주소인지"를 자동 확인한다. 가짜 사이트(예: kbsttar.com)에서는 인증 자체가 시작되지 않는다. 비밀번호는 가짜 사이트에 입력할 수 있지만, FIDO2는 불가능하다.

Apple, Google, Microsoft가 전부 FIDO2를 지원한다. 전 세계 스마트폰에 이미 내장되어 있다. **한국만 1999년에 만든 공인인증서를 2020년까지 유지했다.**

2016년

3D Secure 2.0 — AI가 사기를 잡는다

3D Secure란, 온라인에서 카드로 결제할 때 카드사가 "진짜 본인이 맞나?"를 확인하는 방식이다. Visa의 "Verified by Visa", Mastercard의 "SecureCode"가 이것이다.

2016년 10월, EMVCo(Europay·Mastercard·Visa가 공동 설립한 국제 카드 표준 기관)가 **3D Secure 2.0**을 발표했다. 1.0과의 차이:

	3D Secure 1.0 (2001년)	3D Secure 2.0 (2016년)
인증 방식	매번 비밀번호 입력	AI가 위험도를 판단. 평소 패턴이면 인증 없이 통과
위험 판단	데이터 8개로 판단	**데이터 100개 이상**으로 판단 (기기, 위치, 시간, 구매 패턴 등)
본인 확인	비밀번호	지문, 얼굴, 앱 푸시 알림
사용자 경험	매번 팝업 → 비밀번호 입력	95% 이상은 아무것도 안 해도 됨 (AI가 통과시킴)
프로그램 설치	없음	없음

> **핵심:** 3D Secure 2.0은 AI가 "이 결제가 평소 패턴과 다른가?"를 자동으로 판단한다. 매일 쓰는 카페에서 커피를 사면 아무 인증 없이 통과. 새벽 3시에 해외에서 고가 결제가 들어오면 앱 푸시로 확인. 프로그램 설치: **0개.**

3D Secure 채택 현황

전 세계가 쓰는데, 한국만 안 쓴다

지역	3D Secure 사용 여부
EU 전체 (27개국)	**의무.** PSD2 법에 의해 모든 온라인 카드 결제에 3DS2 필수
영국	**의무.** 브렉시트 후에도 EU의 SCA(Strong Customer Authentication, 강력한 고객 인증) 규정을 그대로 채택
인도	**의무.** 인도중앙은행(RBI)이 모든 온라인 카드 결제에 3DS 의무화
호주, 싱가포르	EU와 유사한 요구사항 도입
브라질, 멕시코	도입 확대 중
한국	**국내 결제에는 미사용.** 해외 결제 시에만 3DS 팝업이 뜸

2023년 기준 전 세계 결제의 **17%**가 3DS2를 사용 (전년 1%에서 급증). 3D Secure는 프로그램을 설치하지 않는다. 전부 브라우저와 카드사 서버 사이에서 처리된다.

한국의 이중 구조

해외 결제는 국제 표준, 국내 결제는 독자 표준

한국 카드사들이 3D Secure를 모르는 건 아니다.

해외 사이트에서 결제할 때

아마존, 스팀 등에서 한국 카드로 결제하면 Visa Secure / Mastercard SecureCode **팝업이 브라우저에 뜬다.** 국제 표준대로 작동한다.

국내 사이트에서 결제할 때

쿠팡, 네이버 등에서 결제하면 3DS를 **안 쓴다.** 대신 SMS 인증 + 카드 비밀번호 앞 2자리라는 독자 방식.

왜 국내에서는 안 쓰나?

- 이미 자체 본인인증 체계(공인인증서, SMS, ISP — Internet Secure Payment, 비씨·국민카드의 자체 결제 인증)를 갖고 있었다
- 국내 PG사(Payment Gateway, 온라인 결제 대행)·VAN사(Value Added Network, 카드 거래 중계)가 3DS와 다른 구조로 만들어져 있다
- "우리 것이 있는데 왜 국제 표준을 써야 하나"라는 인식

"미국에서는 3DS 팝업을 본 적이 없는데?" — 맞다. 미국은 3DS가 의무가 아니고, 쓰더라도 3DS 2.0은 **백그라운드에서 자동 처리**된다 (미국 거래의 74%가 사용자가 아무것도 안 해도 되는 frictionless 방식). 한국에서 해외 결제 시 팝업이 뜨는 건, 한국 카드사가 구형 3DS 1.0 방식(팝업 리다이렉트)을 아직 쓰기 때문이다.

2014년 — 천송이 코트 사건

"별에서 온 그대"가 바꾸려 한 것

전지현이 연기한 천송이와 버버리 코트 (SBS "별에서 온 그대", 2014)

2013년 12월~2014년 2월, SBS 드라마 **"별에서 온 그대"**가 중국에서 폭발적인 인기를 얻었다. 전지현이 연기한 **천송이**라는 캐릭터가 입은 코트를 중국 팬들이 사고 싶어했다.

그런데 **살 수가 없었다:**

- 한국 쇼핑몰 접속 → ActiveX 설치 요구 (중국에서 안 됨)
- 결제 → 공인인증서 필요 (한국 주민번호 필요)
- 본인인증 → 한국 휴대폰 번호 필요
- **외국인은 구매 자체가 불가능**

2014년 3월, 박근혜 대통령이 규제개혁 토론회에서 직접 거론. "중국인들이 천송이 코트를 사고 싶어도 못 산다"며 규제 개혁 지시.

그래서? 30만 원 이상 공인인증서 의무가 풀렸다. 하지만 ActiveX와 보안프로그램은 그대로. 공인인증서 완전 폐지는 **2020년 12월** — 6년 후.

2026년 현재: 공인인증서는 폐지됐지만, 외국인이 한국 온라인 쇼핑몰에서 결제하는 건 **여전히 거의 불가능**하다. 한국 휴대폰 SMS 인증 + 한국 카드사 전용 시스템 + 3D Secure 미사용. **천송이 코트 문제는 12년이 지난 지금도 해결되지 않았다.**

한국에서만 볼 수 있는 것들 (1/2)

세계 어디에도 없는 보안 방식들 — 사용자가 겪는 것

키보드 보안 프로그램

해커가 키보드 입력을 훔쳐보지 못하게, 이 프로그램이 **먼저 키보드 입력을 가로챈다.** 컴퓨터의 가장 깊은 핵심(커널)에서 동작한다. Chrome 웹스토어 평점 **1.3점**/5점.

가상 키패드

비밀번호 칠 때 숫자 배열이 매번 바뀌는 화면 키패드. 마우스로 클릭해서 입력해야 한다. 이 키패드를 제공하는 프로그램에서 오히려 **키로깅 취약점이 발견됐다.**

카드 비밀번호 앞 2자리

온라인 결제 시 4자리 비밀번호 중 **앞 2자리만** 입력. 세계 어디에도 없는 방식. 2자리면 경우의 수가 **100개**뿐이다.

한국에서만 볼 수 있는 것들 (2/2)

보안프로그램이 실제로 하는 일

IPinside — "의무 스파이웨어"

IP 확인이 명목이지만, 실제로는 하드 드라이브 시리얼, 설치 프로그램 목록, 네트워크 설정을 **전부 수집**. 만든 회사(인터리젠)는 빅데이터 수집·판매가 본업. 보안 연구자 Palant: **"의무 설치 스파이웨어"**

커널 레벨 방화벽

AhnLab Safe Transaction이 컴퓨터의 **가장 깊은 핵심(커널)**에서 네트워크 트래픽 전체를 감시. 이 프로그램이 뚫리면 **PC를 완전 장악**할 수 있다.

TLS 암호화 해체

보안프로그램이 브라우저의 암호화 통신을 **중간에서 풀어본다.** 이를 위해 가짜 인증서를 PC에 몰래 등록. 프로그램을 삭제해도 **가짜 인증서는 남아 있다.**

암호화 해체

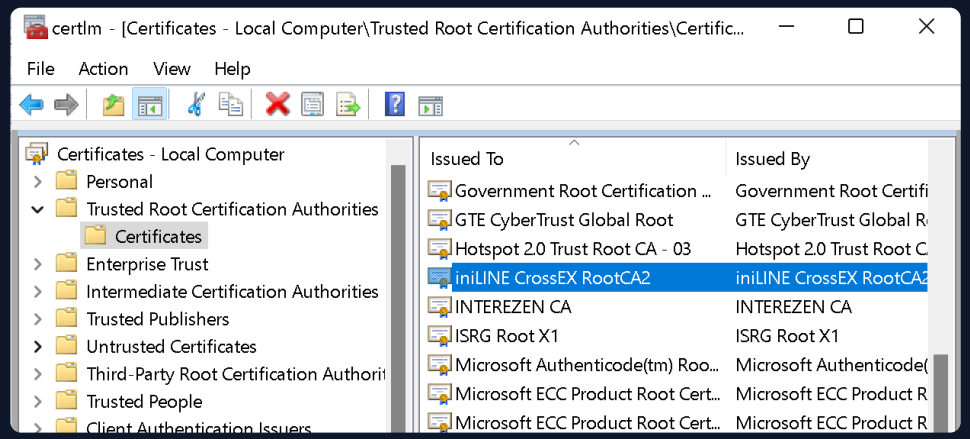
보안프로그램이 브라우저의 보호막을 부순다

TLS(Transport Layer Security)란 인터넷 통신을 암호화하는 기술이다. 편지를 봉투에 넣어서 보내는 것과 같다. 중간에 누가 가로채도 봉투를 열 수 없다.

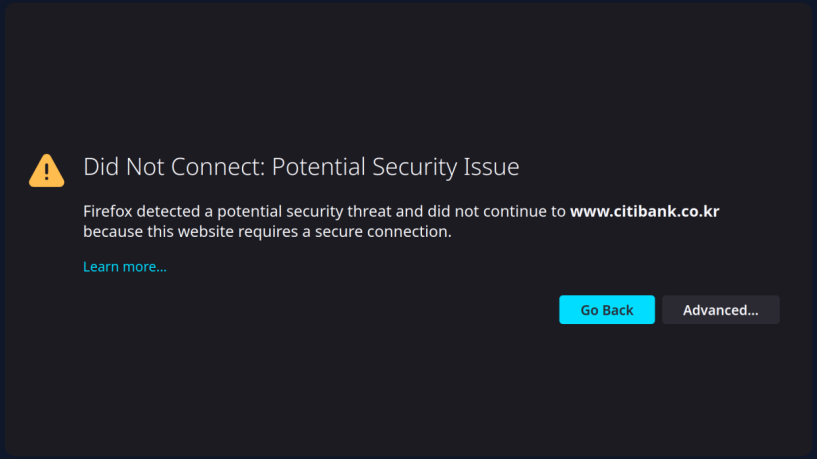
한국 보안프로그램은 이 봉투를 **중간에서 열어본다:**

```
정상: 나 → 🔒 암호화 → 은행
한국: 나 → 🔒 → [보안프로그램이 열어봄] → 🔒 → 은행
```

이를 위해 PC에 **가짜 인증서(Root CA)**를 몰래 등록한다. 이 가짜 열쇠가 유출되면 **한국 전체 인터넷 사용자의 암호화가 무력화**될 수 있다.



보안프로그램이 PC에 등록한 가짜 인증 기관들 (출처: Palant, 2023)



보안프로그램으로 인한 SSL 오류 (출처: Palant, 2023)

Root CA(Root Certificate Authority)란 무엇인가

인터넷 신뢰의 작동 원리

내가 은행 웹사이트에 접속할 때, 브라우저는 "이 사이트가 진짜 은행이 맞는지"를 어떻게 확인할까?

```
1단계: 은행이 "신분증"을 보여준다
  은행 웹사이트가 브라우저에게 인증서를 보낸다.
  인증서에는 "이 사이트는 KB국민은행입니다"라고 적혀 있다.

2단계: 브라우저가 "이 신분증 진짜야?" 확인한다
  누가 이 인증서를 발급했는지 본다.
    → "DigiCert가 발급했네"
    → "DigiCert는 내가 신뢰하는 기관 목록(Root CA)에 있어"
    → "그러면 이 신분증은 진짜다" ✓

3단계: 암호화 통신 시작
  브라우저와 은행 사이에 암호화된 통로가 만들어진다.
  중간에 누가 가로채도 읽을 수 없다. 🔒
```

Root CA(Root Certificate Authority, 루트 인증 기관)란, 브라우저가 "이 기관이 발급한 인증서는 믿겠다"고 미리 정해놓은 **신뢰의 뿌리**다. 전 세계에 수십 개뿐이며, Apple, Google, Microsoft가 엄격하게 심사한다.

한국 보안프로그램이 부수는 것

가짜 Root CA를 PC에 몰래 등록한다

```
보안프로그램이 PC에 "가짜 Root CA"를 몰래 등록한다.

정상 과정:
 나 ←🔒→ 은행      (브라우저가 은행의 진짜 인증서를 확인)

보안프로그램이 개입한 과정:
 나 ←🔒→ [보안프로그램] ←🔒→ 은행

 브라우저는 보안프로그램이 만든 가짜 인증서를 본다.
  "이 인증서를 누가 발급했지?" → "가짜 Root CA"
 그런데 가짜 Root CA가 내 PC에 등록돼 있으니까
  → "신뢰할 수 있는 기관이네" → 통과 ✓

 결과: 보안프로그램이 나와 은행 사이의 모든 통신을
    중간에서 읽을 수 있다. (복호화 → 검사 → 재암호화)
```

"동의를 받지 않나?" — 보안프로그램 설치 시 "설치하시겠습니까?" 팝업에 동의하면, 그 안에 Root CA 설치가 포함되어 있다. Root CA가 설치된다는 사실은 **별도로 고지되지 않는다.** 커널 레벨 권한으로 실행되므로 브라우저가 따로 묻지도 않는다.

> **왜 위험한가:** 이 가짜 Root CA의 개인키가 유출되면, 해커가 한국의 모든 은행, 모든 웹사이트를 사칭할 수 있다. 그리고 보안프로그램을 삭제해도 **가짜 Root CA는 PC에 그대로 남아 있다.** 삭제 기능이 없다.

04

제4부: AI 시대에 ActiveX의 유산

2020년대 — 보안프로그램이 해킹 통로가 됐다

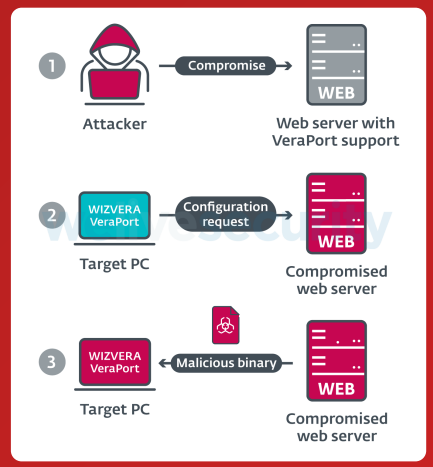
2020년 11월 — 사례 1

북한이 Veraport를 악성코드 배달부로 만들었다

공격자: 북한 라자루스 그룹 (국가 지원 해킹 조직)

보고: ESET (글로벌 보안업체), 2020년 11월 16일

순서	무슨 일이 있었나
1	Veraport가 설치된 웹사이트를 해킹
2	한국 보안업체 두 곳의 **코드 서명 인증서**를 훔침
3	북한 악성코드에 인감을 찍어 "정상 프로그램"으로 위장
4	Veraport의 자동 설치 기능으로 PC에 악성코드 배포
5	PC 원격 조종 백도어 설치 완료



Lazarus 공격 흐름도 (출처: ESET, 2020)

VeraPort 설치 화면 (출처: ESET, 2020)

> 보안을 위해 설치한 프로그램이 **악성코드 배달부** 노릇을 했다.

2023년 1월 — 사례 2

전 국민의 키보드를 엿볼 수 있었다

독일의 보안 연구자 **Wladimir Palant**가 2023년 1월 2일~3월 6일에 걸쳐 한국 보안프로그램들의 취약점을 공개했다.

TouchEn nxKey에서 발견된 7가지 취약점:

- 원격 코드 실행 (해커가 PC를 조종)
- 콜백 인젝션 (악성 웹사이트가 키 입력을 가로챔)
- 평문 키로깅 (암호화 안 된 키 입력)
- 라이선스 위조
- 버퍼 오버플로우 (프로그램 충돌 유발)
- 드라이버 무제한 접근

이 프로그램은 한국 PC에 **1,000만 대 이상** 설치. 하나의 취약점으로 **전 국민의 키보드를 엿볼 수 있는** 상황이었다.

> 키로거를 막겠다고 설치한 프로그램이 **전 국민 규모의 키로거 취약점**을 만들었다.

2023년 11월 — 사례 3

영국·한국 정보기관이 공동 경보를 발령하다

2023년 11월 23일, 영국 NCSC(국가사이버보안센터)와 한국 NIS(국가정보원)가 **사상 최초로 공동 보안 경보**를 발령했다. 북한 라자루스 그룹이 **MagicLine4NX**(드림시큐리티의 금융 인증 프로그램)의 제로데이 취약점을 악용했다는 내용이었다.

순서	공격 과정
1	뉴스 웹사이트를 해킹해서 악성 코드를 심어둠 (워터링 홀 공격)
2	특정 기업 직원들이 뉴스를 읽으면, PC에 설치된 MagicLine4NX의 취약점을 공격
3	MagicLine4NX를 통해 기업 내부 네트워크에 침입
4	내부 이동 → 기밀 데이터 탈취

영국과 한국의 정보기관이 공동으로 경보를 발령할 정도로 심각한 사태였다. 금융 인증을 위해 **의무적으로** 설치된 프로그램이 기업 해킹의 진입점이 된 것이다. 직원에게는 이 프로그램을 안 깔 권리가 없었다.

2025년 — KAIST 논문

학술적으로도 증명됐다 — 19개의 보안 구멍

2025년, KAIST(한국과학기술원) 연구팀이 세계 최고 보안 학회 **USENIX Security**에 논문을 발표했다. 제목: "Too Much of a Good Thing: (In-)Security of Mandatory Security Software for Financial Services in South Korea"

7개 프로그램 분석

한국 금융기관이 의무적으로 설치하게 하는 보안 프로그램 7개를 심층 분석

19개 취약점 발견

키로깅, 원격 코드 실행, 중간자 공격, 개인키 유출, 기기 핑거프린팅

48대 실제 PC 조사

평균 **9개** 보안프로그램 설치. 상당수가 **수년간 업데이트 안 된** 구버전

> **비유:** 집 보안을 강화한다면서 문을 9개 더 뚫어놓은 셈이다. 하나만 부실해도 도둑이 들어온다. KAIST는 그 9개 문 중 7개를 조사했더니, **19개의 자물쇠가 고장나 있었다.**

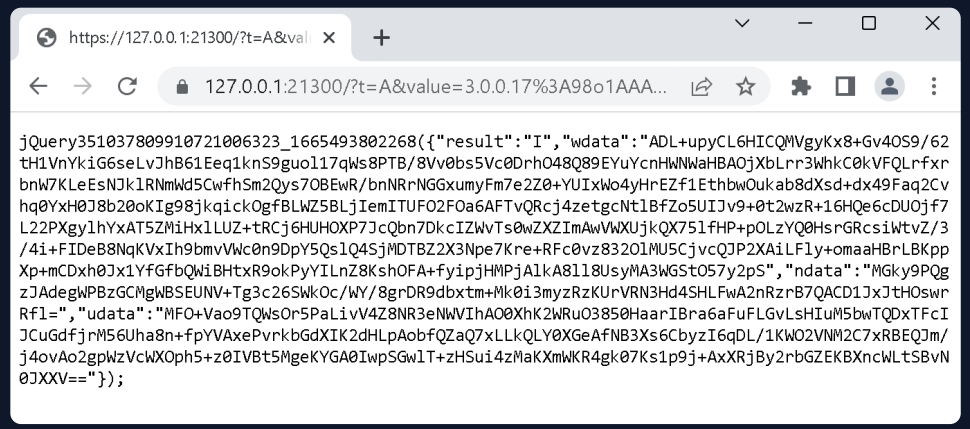
IPinside 상세

"의무 설치 스파이웨어" — 실제로 수집하는 정보

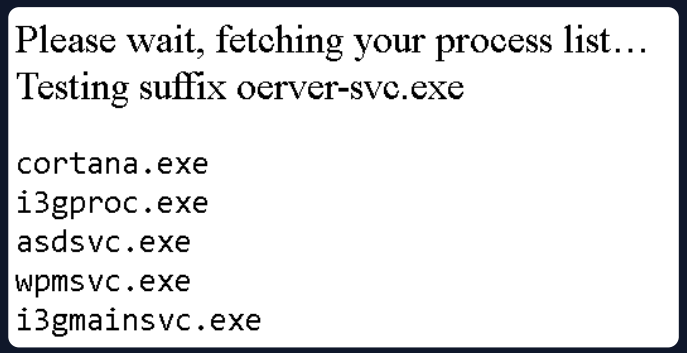
IPinside(인터리젠)가 **IP 확인**이라는 명목으로 실제로 수집하는 정보:

- 하드 드라이브 시리얼 번호
- 설치된 프로그램 목록
- 실행 중인 프로세스 목록
- 네트워크 설정 전체
- 가상머신(VirtualBox 등) 사용 여부
- MAC 주소 (기기 고유 식별자)

인터리젠은 **빅데이터 수집·분석 전문 회사**다. 은행·보험사·정부기관에 데이터를 판매하는 것이 본업이다.



IPinside가 수집하는 데이터 (출처: Palant, 2023)



실행 중인 프로세스까지 수집 (출처: Palant, 2023)

규제 포획

누가 이 시스템을 유지하나

규제 포획(Regulatory Capture)이란, 규제가 시민이 아니라 피규제 업체의 이익을 위해 작동하는 현상이다.

① 금융감독원이 "보안 프로그램 설치하라"고 규정
↓
② 은행이 규정을 따르기 위해 특정 업체 프로그램을 구매
↓
③ 업체는 규제가 보장하는 안정적 수입을 누림
↓
④ 보안 구멍이 발견 → 긴급 패치 계약 → 매출 증가
↓
⑤ 규제를 바꿀 인센티브가 누구에게도 없음
↓
① 으로 돌아감

이해관계자	바꿀 이유가 없는 이유
금감원	규정 바꾸면 "보안을 약화시켰다"는 비난 리스크
은행	"규정대로 했으니 면책" — 바꿀 이유 없음
보안업체	규제가 매출을 보장 — 바꿀 이유 없음
퇴직 공무원	금융위·금감원 퇴직 후 금융결제원·인증기관 임원으로 이동

시장 규모

이 시장의 연간 비용 — 2~4조 원

USENIX Security 2025 논문은 **"세계에서 한국만 이런 소프트웨어를 강제한다"**고 확인했다. 이 한국만의 시스템이 경제에 미치는 총 비용:

소프트웨어 라이선스

1,500~2,500억

5개 업체 합산 금융보안 매출

은행 IT 지원 비용

2,000~4,000억

보안프로그램 오류 대응 콜센터 + 원격 설치 지원

망분리 유지비

2,000~3,000억

금융권 40만 명 이중 PC 하드웨어 + 유지보수

사용자 생산성 손실

1.5~3조 원/년

인터넷 뱅킹 사용자 약 3,000만 명 × 연간 2~4시간 (설치, 업데이트, 오류 대응, 호환성 문제 해결) × 평균 시급 25,000원

세계 비교

0원

미국·영국·일본·EU는 클라이언트 보안프로그램을 강제하지 않는다. 이 비용이 존재하지 않는다.

수익자들

그런데 누구도 돈을 못 번다

은행이 보안프로그램을 "가장 싼 것"으로 구매해서 면책 근거로 쓰기 때문에, 보안업체들의 영업이익은 처참하다. (한국경제 보도)

회사	프로그램	2024 매출	영업이익
라온시큐어	TouchEn nxKey	624억 원	**19.6억 원**
안랩	Safe Transaction	2,606억 원 (전사)	—
드림시큐리티	MagicLine4NX	304억 원	**10억 원**
위즈베라	Veraport	~68억 원	**21억 원**
인터리젠	IPinside	비공개	비공개

> **핵심 아이러니:** 연간 2~4조 원의 비용이 발생하는데, 보안업체 영업이익은 합쳐봤자 수십억 원. 비용의 대부분은 사용자 생산성 손실과 은행 IT 지원 비용으로 사라진다. **누구도 돈을 못 벌면서 전 국민이 비용을 부담하는 구조.**

사용자에게 선택권은 없다. 월급을 받으려면 은행을 써야 하고, 은행을 쓰려면 프로그램을 깔아야 한다. **거부하면 서비스 자체를 사용할 수 없다.**

결제 갈라파고스

왜 한국에서만 Stripe가 안 되나

Stripe는 전 세계 수백만 기업이 사용하는 결제 서비스다. 개발자가 코드 몇 줄이면 카드 결제를 받을 수 있다. 한국에서는 안 된다.

해외 결제 구조

```
고객 → Stripe → Visa/Mastercard → 카드사   (끝)
```

한국 결제 구조

```
고객 → PG사(Payment Gateway, 결제 대행: 이니시스/KCP/토스)
     → VAN사(Value Added Network, 거래 중계)
     → 개별 카드사
(각 단계마다 수수료, 각 단계마다 별도 계약)
```

장벽	내용
법인 등록	한국 사업자등록번호 없으면 PG사(결제 대행사) 가입 불가
허가	외국 기업이 결제 서비스를 하려면 금융위원회 허가 (사실상 불가)
프로토콜	한국 카드사의 통신 방식이 세계 표준과 다름
본인인증	국제 표준(3D Secure) 미사용. 독자 인증(SMS + 공동인증서)

결제 경험 비교

같은 일을 할 때

하려는 일	한국에서	미국/유럽에서
온라인 쇼핑 결제	보안프로그램 5개 설치 → 공동인증서 → 가상키패드 → 카드 비번 앞2자리 → SMS	카드번호 입력 → 끝 (필요시 앱 푸시 한 번)
은행 이체	보안프로그램 5개 설치 → 공동인증서 → OTP/보안카드	은행 앱에서 지문 인증 → 끝
해외 사이트 결제	안 됨 (한국 결제 시스템이 안 붙음)	카드번호 입력 → 끝
외국인이 한국에서 결제	거의 불가 (한국 인증 체계 요구)	Apple Pay 터치 → 끝

세계 vs 한국 — 2026년 현재

한국

프로그램 **5~9개** 설치 필수
맥/아이패드 사용 불가
외국인 사용 불가
사고 시 **사용자** 책임

세계

프로그램 설치 **0개**
어떤 기기에서든 가능
누구나 사용 가능
사고 시 **금융기관** 책임

결제 구조

왜 한국에는 KG이니시스가 필요한가

해외에서는 Stripe 하나로 모든 카드 결제가 된다. 한국에서는 PG사 → VAN사 → 카드사라는 다단계 구조가 필요하다.

해외 결제 구조

```
고객
 ↓
Stripe (PG) ———→ Visa/Mastercard
                        ↓
                  카드 발급 은행
```

중간 업체: 1개
수수료: 약 2.9%

한국 결제 구조

```
고객
 ↓
KG이니시스 (PG) → NICE (VAN) → 삼성카드
                               → 현대카드
                               → 하나카드
                               → ...각각 별도 연동
```

중간 업체: 2개 + 카드사별 개별 계약
수수료: 중첩 발생

왜 이런 구조가 생겼나: 한국 카드사들이 글로벌 표준 프로토콜(Visa/Mastercard 직접 연동)을 안 쓴다. 카드사마다 통신 방식이 달라서, 가맹점이 일일이 연동할 수 없다. 그래서 "중간에서 연결해줄게" → PG사(이니시스, KCP), "거래를 중계해줄게" → VAN사(NICE, KSNET)가 탄생했다. Stripe가 한국에 못 들어오는 이유이기도 하다.

글로벌 표준의 한국화

3D Secure도 한국에 오면 이렇게 된다

같은 3D Secure 프로토콜인데, 카드사가 응답하는 방식이 다르다. Mastercard는 "본인 확인해"라고만 한다. **어떻게** 확인하는지는 카드사가 결정한다.

항목	해외 카드 (Chase, Revolut 등)	한국 카드 (하나, 삼성 등)
인증 방식	이메일 코드, 은행 앱 푸시, 또는 자동 통과	**"앱카드를 설치해주세요"**
앱 없으면?	브라우저 팝업으로 대체 가능	**결제 불가**
자동 통과율	95% 이상 (AI 위험도 판단)	거의 없음 — 매번 인증
앱 구조	기존 은행 앱 하나로 통합	카드사마다 별도 앱카드 앱
최초 설정	없음 (은행 앱 이미 있음)	앱 설치 → 회원가입 → 본인인증 → 카드등록
소요 시간	3초	5~10분 (첫 결제 시)

같은 하나카드인데:

- 해외 사이트(Amazon)에서 쓸 때 → 3D Secure → 앱카드 설치 강요
- 다른 나라 카드(Chase)로 같은 사이트 결제 → 이메일 코드 한 번이면 끝
- 국내 사이트(쿠팡)에서 쓸 때 → 3D Secure 자체를 안 씀 → SMS + 비밀번호 앞 2자리

글로벌 표준을 도입해도, "사용자가 뭔가를 깔고 매번 증명해야 한다"는 한국의 철학이 적용되면 이렇게 된다. 마차에 엔진을 달아놓고 여전히 말이 끄는 구조다.

2020년 이후

인증서 춘추전국시대

2020년 공인인증서 독점은 폐지됐다. 하지만 "인증서"라는 틀 자체는 유지됐다.

인증서	운영 주체	동기
카카오 인증서	카카오	4,700만 사용자 → 인증 시장 선점, 데이터 확보
네이버 인증서	네이버	카카오에 뺏기면 안 됨
PASS 인증서	SKT/KT/LGU+	본인인증(SMS) 시장 사수
토스 인증서	토스	금융 플랫폼 확장
KB모바일 인증서	국민은행	고객 이탈 방지
국민인증서	행정안전부	공공서비스용
공동인증서	금융결제원	기존 수익원 사수

결과: 사용자는 서비스마다 다른 인증서를 발급받아야 한다. 은행 갈 때 하나, 정부 민원 때 하나, 카카오 또 하나. 인증서가 1개에서 7개 이상으로 늘었을 뿐, 사용자의 부담은 오히려 증가했다.

근본 진단

주차권을 자꾸 잃어버리니까 더 많은 주차권을 만들었다

주차권을 잃어버리는 문제를 "더 다양한 주차권"으로 해결하려 했다. 주차권을 없앨 생각은 안 했다.

한국의 해결책: "더 다양한 주차권을 만들자"

앱 주차권 (카카오 인증서)
핸드폰 주차권 (PASS 인증서)
은행 전용 주차권 (KB모바일 인증서)
정부 전용 주차권 (국민인증서)
결과: 주차권이 1개에서 7개로 늘었다

글로벌의 해결책: "주차권을 없애자"

번호판 인식 → 자동 입출차
주차권이 없으니 잃어버릴 것도 없음
복사 불가, 관리 불필요
프로그램 설치: 0개

```
주차권을 줬더니 파생 산업이 통째로 생겼다:
  주차권 발급 (인증기관) → 주차권 보관함 (USB) → 주차권 관리 프로그램 (ActiveX)
  → 주차권 전달 프로그램 (Veraport) → 주차권 보호 프로그램 (TouchEn) → 주차권 분실 면책 (제9조)

주차권을 없애면 이 산업이 전부 사라진다. 그래서 아무도 바꾸고 싶어하지 않는다.
```

한국 주차장은 진작에 번호판 인식으로 바꿨다. 세계 금융도 바꿨다. 한국 은행만 아직도 주차권을 나눠주고 있다.

한국만의 구조

휴대폰 없으면 아무것도 할 수 없는 나라

한국은 모든 온라인 서비스에 휴대폰 본인인증을 요구한다. 미국은 이메일이면 충분하다.

상황	한국	미국
쇼핑몰 회원가입	휴대폰 본인인증 필수	이메일만 있으면 됨
게임 계정 생성	휴대폰 본인인증 필수	이메일만 있으면 됨
비밀번호 찾기	휴대폰 인증	이메일 링크
커뮤니티 댓글	휴대폰 인증 필수	익명 가능
은행 이체	휴대폰 인증 + 인증서	로그인 + 서버 FDS
휴대폰 없으면?	**아무것도 못 함**	이메일로 대체 가능

```
주민등록번호 수집 금지 (2014년)
  → 대체 수단 필요
  → 통신사가 "우리가 하겠다"
  → 통신사가 주민번호와 휴대폰 번호를 연결해 놨으니까
  → 휴대폰 인증 = 실명 확인
  → 통신사가 모든 온라인 서비스의 관문을 장악
```

미국에서 SSN을 웹사이트 회원가입에 입력하라고 하면 100% 사기다. 한국에서는 2014년까지 모든 웹사이트가 주민등록번호를 수집했다. 지금은 주민번호 대신 휴대폰 인증이 그 역할을 하고 있을 뿐이다.

여권의 비유

주민등록번호가 문제가 아니라 남용이 문제다

한국, 독일, 일본, 스웨덴 전부 국민 ID가 있다. 차이는 어디까지 요구하느냐다.

적절한 사용 (모든 나라)

은행 계좌 개설 (자금세탁 방지)
증권 거래 (내부자 거래 감시)
정부 민원 (세금, 복지)
통신사 후불 계약

한국만 요구하는 곳

온라인 쇼핑몰 회원가입 · 게임 계정 생성
커뮤니티/SNS 가입 · 배달 앱 가입
OTT 서비스 가입 · 와이파이 가입

```
비유: 주민등록번호 = 여권

다른 나라: 여권은 출입국과 은행에서만 보여준다.
한국: 편의점 들어갈 때도 여권을 보여줘야 한다.
      2014년에 "여권 직접 제시"는 금지됐지만,
      대신 "여권 번호를 아는 통신사가 대신 확인해줌"으로 바뀜.
      본질은 같다.
```

EU GDPR의 "데이터 최소화 원칙" — 서비스에 꼭 필요한 정보만 수집해야 한다. 쇼핑몰이 주민번호를 수집하면 불법이다. 한국은 정반대 방향으로 가고 있다.

종합

문제의 핵심: 보안의 책임을 사용자에게 떠넘기는 구조

지금까지 다룬 모든 문제를 관통하는 하나의 구조가 있다.

한국

영역	방법	책임
암호화	사용자 PC에 프로그램 설치	사용자
인증	사용자가 인증서(개인키) 관리	사용자
본인확인	사용자가 매번 증명	사용자
사고 시	"프로그램 안 깔았으니 네 잘못"	사용자

글로벌

영역	방법	책임
암호화	서버에서 TLS 처리	서비스 제공자
인증	서버가 MFA+FDS로 판단	서비스 제공자
본인확인	서버가 행동 패턴으로 판단	서비스 제공자
사고 시	"서버 보안 부족이면 은행 잘못"	서비스 제공자

```
뿌리 1: 국민 관리 사상 (1968~)
  주민등록제도 → 인터넷 실명제 → 휴대폰 본인인증

뿌리 2: 책임 회피 규제 (1999~)
  전자서명법 → 보안프로그램 의무화 → 면책 구조

뿌리 3: 규제가 만든 이권 (2005~)
  보안프로그램 업체 → 인증기관 → 통신사 본인인증
```

한국 IT 보안의 근본 문제는 기술이 아니라 철학이다. "보안의 책임이 누구에게 있는가"에 대해 한국은 사용자를, 세계는 서비스 제공자를 지목한다. 이 하나의 차이에서 인증서, 보안프로그램, 휴대폰 인증, 면책 구조가 전부 갈라진다.

AI 시대

AI 시대에 주차권을 나눠주는 나라

AI 에이전트가 사용자를 대신해 일하는 시대가 왔다. 한국의 인증 체계는 AI가 작동할 수 없는 구조다.

상황	글로벌	한국
"AI야, 잔고 확인해줘"	API 키 + OAuth → AI가 은행에 접근	보안프로그램 설치 팝업 → **AI 접근 불가**
"AI야, 결제해줘"	Stripe API → AI가 자동 결제	휴대폰 본인인증 → **사람만 가능**
"AI야, 서류 제출해줘"	정부 API → AI가 자동 처리	공동인증서 + 보안프로그램 → **AI 불가**
AI 보안 강화	서버측 AI FDS가 이상거래 실시간 판단	클라이언트 프로그램이 키보드 감시 → **AI 적용 불가**

```
주차장 비유로 보면:

[글로벌]  번호판 인식(3세대) → 자율주행차가 스스로 입출차 가능
          AI 에이전트가 API로 금융·결제·정부 서비스에 자동 접근

[한국]    물리 주차권(1세대) → 자율주행차가 주차권을 받을 수 없음
          AI 에이전트가 인증서 설치, 휴대폰 인증을 할 수 없음
          → 한국만 AI 경제에서 고립
```

클라이언트는 점점 다양해진다. PC → 맥 → 리눅스 → 스마트폰 → 태블릿 → AI 에이전트 → 로봇 → IoT. 클라이언트에 프로그램을 설치하는 방식은 새 기기가 나올 때마다 막힌다. 한국에서 맥으로 은행 업무가 힘든 이유, 리눅스로 불가능한 이유, AI 에이전트가 접근 못 하는 이유가 전부 같다. 앞으로 로봇이 심부름을 하는 시대가 오면? 로봇에 보안프로그램을 설치할 건가? **서버에서 처리하면 클라이언트가 뭐든 상관없다.**

전환 경로

누가 무엇을 바꿔야 하는가

6개 이해관계자 각각의 핵심 과제를 한 눈에 보여주는 요약 테이블.

이해관계자	핵심 과제	시기
국회	전자금융거래법 제9조 면책구조 개정, 전자서명법에 FIDO2 인정	2027년
금융위원회	보안프로그램 설치 의무 폐지, 오픈API 의무화	2027년
은행/카드사	서버측 FDS 투자, 3D Secure 2.0 국내 적용, 패스키 도입	2027-2029년
PG사/VAN사	글로벌 결제 네트워크 직접 연동, PCI DSS 인증	2027-2028년
인터넷 서비스	휴대폰 본인인증 탈피, 이메일+MFA 전환	2027-2028년
통신사	본인인증 독점 해소, 수수료 투명화	2027-2028년

핵심 원칙: "뭘 깔아라"가 아니라 "뭘 달성해라". 기술을 지정하는 규제에서 목표를 지정하는 규제로 전환.

국회

국회: 법을 바꿔야 한다

상임위원회	법률	핵심 개정 내용	시기
정무위원회	전자금융거래법	제9조 면책구조 → 금융기관 책임 원칙 (EU PSD2 모델)	2027년
정무위원회	전자금융감독규정	제15조 보안프로그램 설치 의무 → 서버사이드 보안으로 대체	2027년
과방위	전자서명법	FIDO2/패스키를 법적 전자서명 수단으로 인정	2027년
과방위	정보통신망법	SMS OTP 단독 인증 금지 조항 신설	2028년
정무위	여신전문금융업법	VAN 수수료 투명화, 카드 네트워크 직접 연동 허용	2027년
행안위	주민등록법	온라인 본인확인 시 주민번호 전체 수집 금지	2028년

> 싱가포르는 2024년에 SMS OTP를 폐지했다. UAE는 2026년 3월, 인도는 4월, 필리핀은 6월에 폐지한다. 한국만 아직 논의조차 시작하지 않았다.

정부

정부: 규정을 바꿔야 한다

부처	핵심 과제	구체적 행동	시기
금융위원회	보안프로그램 폐지	전자금융감독규정 제15조 개정 → 서버사이드 FDS로 대체	2027 Q1
금융위원회	오픈API 의무화	은행의 오픈API 제공을 법적 의무로 격상	2028
금융감독원	PCI DSS 권고	대형 PG사·카드사에 PCI DSS 4.0.1 인증 의무화	2027-28
과기정통부	SMS OTP 폐지	싱가포르 MAS 벤치마킹, 단계적 폐지 로드맵 발표	2027 Q1
과기정통부	본인확인기관 확대	DID 기관, 핀테크 기업을 본인확인기관으로 추가 지정	2027
행정안전부	공공서비스 패스키	정부24, 홈택스에 패스키 로그인 필수 지원	2027 H2
개인정보보호위	ISMS-P 강화	인증 기준에 "피싱방지 인증(FIDO2) 지원" 항목 추가	2027.7

은행과 카드사: 기술을 바꿔야 한다

과제	구체적 행동	해외 사례	시기
FDS 고도화	AI 기반 실시간 이상거래탐지. 클라이언트 의존도 연 10% 축소	영국 Barclays: AI FDS로 사기 탐지율 40% 향상	2026-28
패스키 도입	인터넷·모바일뱅킹에 패스키 필수 제공	싱가포르 DBS Bank: 2024년 패스키 전환	2026-28
3D Secure 2.0	국내 결제에도 3DS 2.0 정식 도입	일본: 2025년 전 가맹점 의무화	2027
보안프로그램 폐지	키보드보안·방화벽 등 단계적 폐지 (2027 옵션→2029 완전 폐지)	JP Morgan, HSBC: 설치 프로그램 0개	2027-29

> 이 기술들은 새로 발명할 것이 없다. TLS, FDS, FIDO2, 3D Secure — 전부 이미 검증된 글로벌 표준이다.

결제/인증 업체

PG사·VAN사·통신사: 구조를 바꿔야 한다

PG사/VAN사

- 글로벌 결제 네트워크(Visa/Mastercard) 직접 연동 추진
- PCI DSS 4.0.1 인증 의무 취득
- EMV 토큰화 도입 → 카드번호 유통 차단
- VAN사: 단순 중계 → 데이터 분석·AI 사기탐지로 전환

벤치마킹: 인도 UPI — 개방형 결제 인프라, 무료, 독점 방지

통신사

- 본인확인기관 추가 지정 수용 (DID, 핀테크)
- 건당 23~30원 수수료 투명화 및 인하
- PASS 인증 API 오픈API로 공개
- DID 기반 자기주권 인증으로 전환

벤치마킹: 에스토니아 e-ID — 통신사 의존 없는 국가 디지털 ID

타임라인

단계별 실행 로드맵

1년 차 — 2027년: 기반 조성

- 전자금융감독규정 보안프로그램 조항 개정
- 5대 시중은행 패스키 로그인 의무화
- SMS OTP 폐지 로드맵 발표
- PCI DSS 인증 공식 권고
- 본인확인기관 추가 지정

2년 차 — 2028년: 전환 가속

- SMS OTP 단독 인증 금지 (금융)
- 대형 PG사 PCI DSS 인증 의무화
- 오픈API 제공 의무화
- 공공서비스 패스키 필수 지원
- 주민번호 온라인 수집 최소화

5년 차 — 2030년: 체계 완성

- 클라이언트 보안프로그램 완전 폐지
- SMS OTP 완전 폐지
- 글로벌 PSP(Stripe 등) 정상 진입
- DID 인증 이용률 60%

핵심 지표

목표 지표 — 2030년까지

지표	현재 (2026년)	2028년 목표	2030년 목표
패스키 도입 금융기관	~10개	전 은행·증권사	전 금융기관
보안프로그램 설치 요구	~95%	50% 이하	0%
PCI DSS 인증 PG사	~10%	60% 이상	100%
SMS OTP 의존 서비스	~80%	30% 이하	0%
외국 PSP 한국 등록	0개	3개 이상	10개 이상
DID 인증 이용률	~5%	30%	60%

> 한국 주차장이 번호판 인식으로 전환하는 데 10년이 걸리지 않았다. 금융 보안도 마찬가지다. 기술은 이미 있다. 결정만 하면 된다.

FAQ (1/3)

자주 묻는 질문 — 보안

질문	답변
"보안프로그램을 없애면 해킹당하지 않나?"	오히려 반대다. 보안프로그램 자체가 해킹 통로가 되고 있다. **실제 사례 3건:** ① 2020년 북한 Veraport 악성코드 배포 ② 2023년 TouchEn nxKey 전 국민 키로깅 취약점 ③ 2023년 MagicLine4NX 영국·한국 공동 경보. 미국·영국·일본·EU·호주·싱가포르 — **세계 어느 나라 정부도 이런 프로그램을 요구하지 않는다.** 보안은 서버에서 해야 한다.
"다른 나라는 정말 프로그램 없이 안전한가?"	안전하다. 미국·영국·일본·EU·호주·싱가포르 — 어느 나라도 보안프로그램 설치를 요구하지 않는다. 대신 **HTTPS(TLS) 암호화 + FIDO2(지문/얼굴 인증) + AI 이상거래탐지(FDS)**를 서버에서 처리한다. 이 나라들이 보안에 무관심한 게 아니라, **더 안전한 방법을 찾은 것**이다. 한국 방식(PC에 프로그램 설치)은 오히려 해킹 통로가 된다는 것이 KAIST 논문과 북한 해킹 사례 3건으로 증명됐다.
"공인인증서가 없어지면 어떻게 인증하나?"	**FIDO2(Fast Identity Online)** — 지문/얼굴 인증. 이미 아이폰 Face ID, 갤럭시 지문인식에 내장되어 있다. 프로그램 설치 불필요. 가짜 사이트에서는 인증 자체가 시작되지 않아 **피싱에 원천 면역**. 또는 카카오/네이버 간편인증으로도 가능.

FAQ (2/3)

자주 묻는 질문 — 데이터와 산업

질문	답변
"클라우드에 데이터를 올리면 미국으로 유출되지 않나?"	AWS·Google·Azure 모두 **서울에 데이터센터**를 운영 중이다. 글로벌 클라우드를 쓴다고 해서 데이터가 미국으로 넘어가는 게 아니다. 서울 서버에 저장된다. 그리고 기업용 AI(API/Enterprise)는 **데이터를 학습에 사용하지 않는다** — OpenAI, Anthropic, Google 3사 모두 공식 정책으로 보장. ZDR(Zero Data Retention) 옵션을 쓰면 **처리 즉시 삭제, 어디에도 남지 않는다.**
"보안 업체들이 다 망하는 거 아닌가?"	PC 감시 소프트웨어 → **서버 보안, AI 위협 탐지**로 전환하면 시장이 오히려 더 커진다. 글로벌 서버 보안 시장은 PC 보안 시장의 수십 배 규모. 또한 한컴은 **Notion 같은 AI 기반 Markdown 문서 편집기**로 전환할 수 있다 — HWP 파일 변환은 한컴만 가능하고, 한국어 맞춤법·공문서 서식은 Notion에 없는 차별점이다.
"네이버처럼 갈라파고스여서 지켜진 산업도 있지 않나?"	네이버와 보안프로그램은 근본적으로 다르다. **네이버는 한국 사용자에게 더 나은 서비스를 만들어서 이겼다** — 한국어 검색, 카페, 블로그, 지식iN은 구글보다 한국인에게 더 유용했다. 구글이 "못 들어온" 게 아니라 네이버가 더 잘한 것이다. 반면 **보안프로그램은 법으로 강제한 것이다.** Chrome 평점 1.3점. 아무도 원하지 않는다. 네이버는 보호주의의 성공 사례이고, 보안프로그램은 규제 포획의 실패 사례다.

FAQ (3/3)

자주 묻는 질문 — 역사와 전환

질문	답변
"1999년의 전자서명법은 잘못된 결정이었나?"	아니다. **당시에는 합리적이었다.** 미국이 128비트 암호화 수출을 금지하고 있었고, 한국이 자체 암호화(SEED)를 개발해서 ActiveX로 구현한 것은 현실적 유일한 대안이었다. 문제는 **2000년에 미국이 수출 제한을 풀었는데도 21년간 바꾸지 않은 것**이다.
"왜 지금까지 안 바꿨나?"	**규제 포획(Regulatory Capture).** ① 금감원: 규정 바꾸면 "보안을 약화시켰다"는 비난 리스크 ② 은행: "규정대로 했으니 면책" — 바꿀 이유 없음 ③ 보안업체: 규제가 매출을 보장 — 바꿀 이유 없음 ④ 퇴직 공무원: 금융위·금감원 → 금융결제원·보안업체 회전문 인사. **시스템 안의 모든 이해관계자에게 바꿀 인센티브가 없다.**
"다른 나라 정부도 정말 AI를 업무에 쓰고 있나?"	**미국:** 연방 공무원 9만 명이 ChatGPT 사용 중, 1,800만 건 질문. OpenAI·Anthropic이 정부 전체에 기관당 연 1달러로 AI 제공. **싱가포르:** 정부 전용 AI 챗봇 "Pair" — 100개 기관, 11,000명 사용. **영국:** 공무원 AI 교육 10만 명 등록. **UAE:** 정부 기관 AI 활용률 97%.
"한국도 결국은 바뀌고 있지 않나?"	방향은 맞지만 속도가 문제다. 2020년 공인인증서 "폐지" → 이름만 "공동인증서"로 바뀜. 2025년 전자금융감독규정 개정 → 293개→166개 규칙 축소, "원칙 중심" 방향 제시. **하지만 은행은 여전히 보안프로그램 설치를 요구하고, 전자금융거래법 제9조의 면책 구조는 그대로.** 법의 방향은 바뀌고 있지만, 현실은 아직 2005년에 머물러 있다.

AI 규제에 대한 교훈: 초기에 합리적으로 보이는 규제 결정이, 특정 기술을 법으로 고정하면, 수십 년간의 기술 고착(lock-in)을 만들 수 있다. 규제는 **기술이 아니라 목표**를 지정해야 한다.

참고 자료

출처

보안 연구

• **Wladimir Palant** (palant.info, "Almost Secure" 블로그)
— 독일 쾰른 기반 보안 연구자. Adblock Plus 공동 창시자.
— 2023년 1~3월 한국 보안프로그램 6편의 심층 분석 시리즈 발표.
— TouchEn nxKey 7개 취약점 발견, IPinside를 "의무 스파이웨어"로 규정.
→ "South Korea's online security dead end" (2023.01.02)
→ "TouchEn nxKey: The keylogging anti-keylogger" (2023.01.09)
→ "IPinside: Korea's mandatory spyware" (2023.01.25)
→ "Weakening TLS protection, South Korean style" (2023.02.06)
• **KAIST** / USENIX Security '25, "Too Much of a Good Thing"
— 한국과학기술원 연구팀. 세계 최고 보안 학회 USENIX Security에 발표.

해킹 사례

• ESET, "Lazarus supply-chain attack in South Korea" (2020.11.16)
• UK NCSC & Korea NIS, Joint Advisory on MagicLine4NX (2023.11.23)

한국 IT 역사

• 전자서명법 (1999.07 제정, 2020.12 개정)
• UN E-Government Survey 2010, 2012, 2014
• ITU, "Korean Broadband Case Study" (2003)

글로벌 보안 표준

• PCI DSS v1.0 (2004.12), PCI SSC (2006.09)
• FIDO Alliance (2012.07 설립)
• EU PSD2 (2015.11 채택, 2019.09 SCA 시행)
• 3D Secure 2.0 (EMVCo, 2016.10)
• US EO 14028 제로트러스트 (2021.05.12)

결제 시스템

• Stripe, "How to accept payments in South Korea"
• The Paypers, "South Korea: 2025 payments analysis"

상세 보고서

• 유호현, "왜 한국에서만 은행 업무를 하려면 이상한 프로그램을 깔아야 할까?" (옥소폴리틱스, 2026)
• hohyon.com/ko/reports/korea-payment-security

감사합니다

유호현
대표, (주)옥소폴리틱스

hohyon.com · oxopolitics.com

본 발표는 개인 의견이며 특정 기관의 공식 입장이 아닙니다